

Network Security

Week 1 Day 4

Firewalls & IDS

Today!

- Firewalls
- Intrusion Detection Systems

bristol.ac.uk



Network Security Design

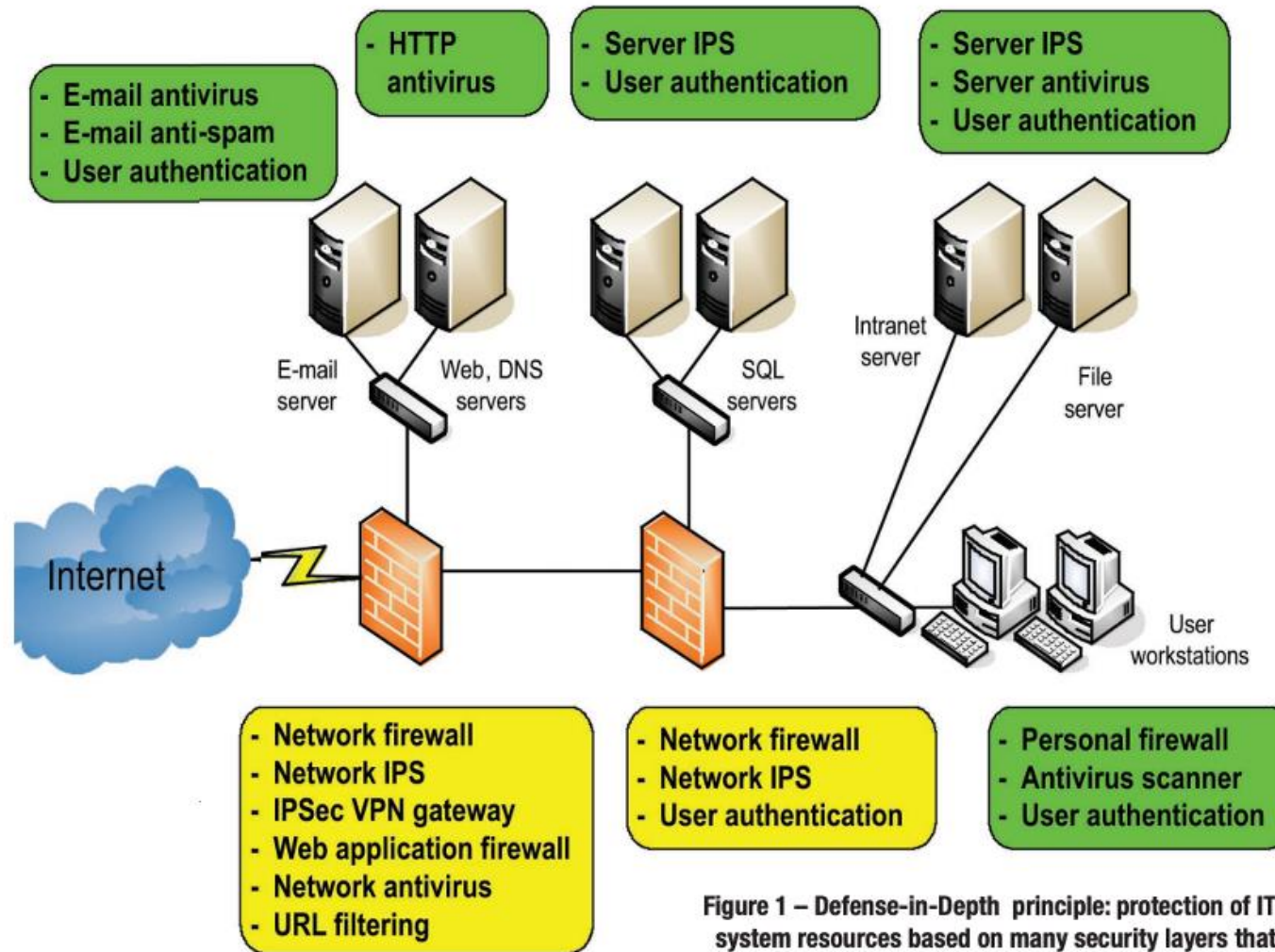
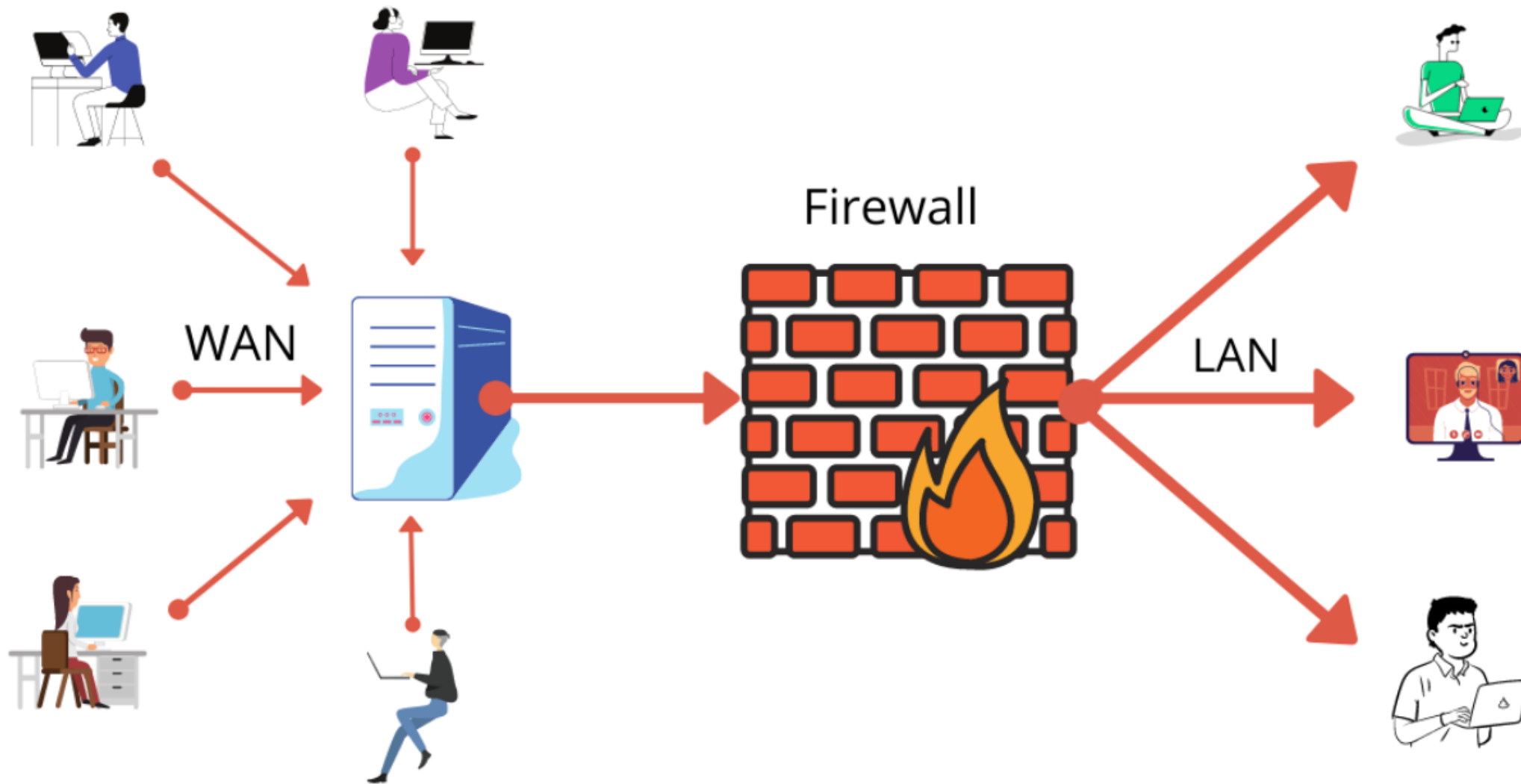


Figure 1 – Defense-in-Depth principle: protection of IT system resources based on many security layers that complement one another.



bristol.ac.uk

Firewalls

- A firewall is a device that filters all traffic between a protected or "inside" network and a less trustworthy or "outside" network.
 - Usually a firewall runs on a dedicated device because it is a single point through which traffic is channeled, performance is important
 - Non-firewall functions should not be done on the same machine.
 - Firewall code usually runs on a proprietary or carefully minimized operating system
 - More code means more security problems
 - The purpose of a firewall is to keep "bad" things outside a protected environment.
 - firewalls implement a security policy that is specifically designed to address what bad things might happen
 - determining security policies is challenging!

Firewalls

- People in the firewall community (users, developers, and security experts) disagree about how a firewall should work.
 - the community is divided about a firewall's **default behavior**
 - two schools of thought
 - “that which is not expressly forbidden is permitted” (default permit)”
 - “that which is not expressly permitted is forbidden” (default deny)”.

Design of Firewalls

- The firewall must be
 - always invoked
 - ensure that all network accesses that we want to control must pass through it
 - Tamperproof
 - A firewall is typically well isolated, making it highly immune to modification
 - small and simple enough for rigorous analysis
 - firewall designers strongly recommend keeping the functionality of the firewall simple

Firewalls

- *A mechanism used to protect a trusted network from an untrusted network.*
- A mechanism to enforce access control policy.
- Software or Hardware based.
- Deployed as gatekeeper.
- Examples: *ipchain/iptables, Cisco PIX, Juniper, MS ISA.*

Firewall's (in)capabilities

Firewall's (in)capabilities

✓ Provide a focal point for monitoring.

Firewall's (in)capabilities

- ✓ Provide a focal point for monitoring.
- ✓ Provide a central point for access control (who can do what).

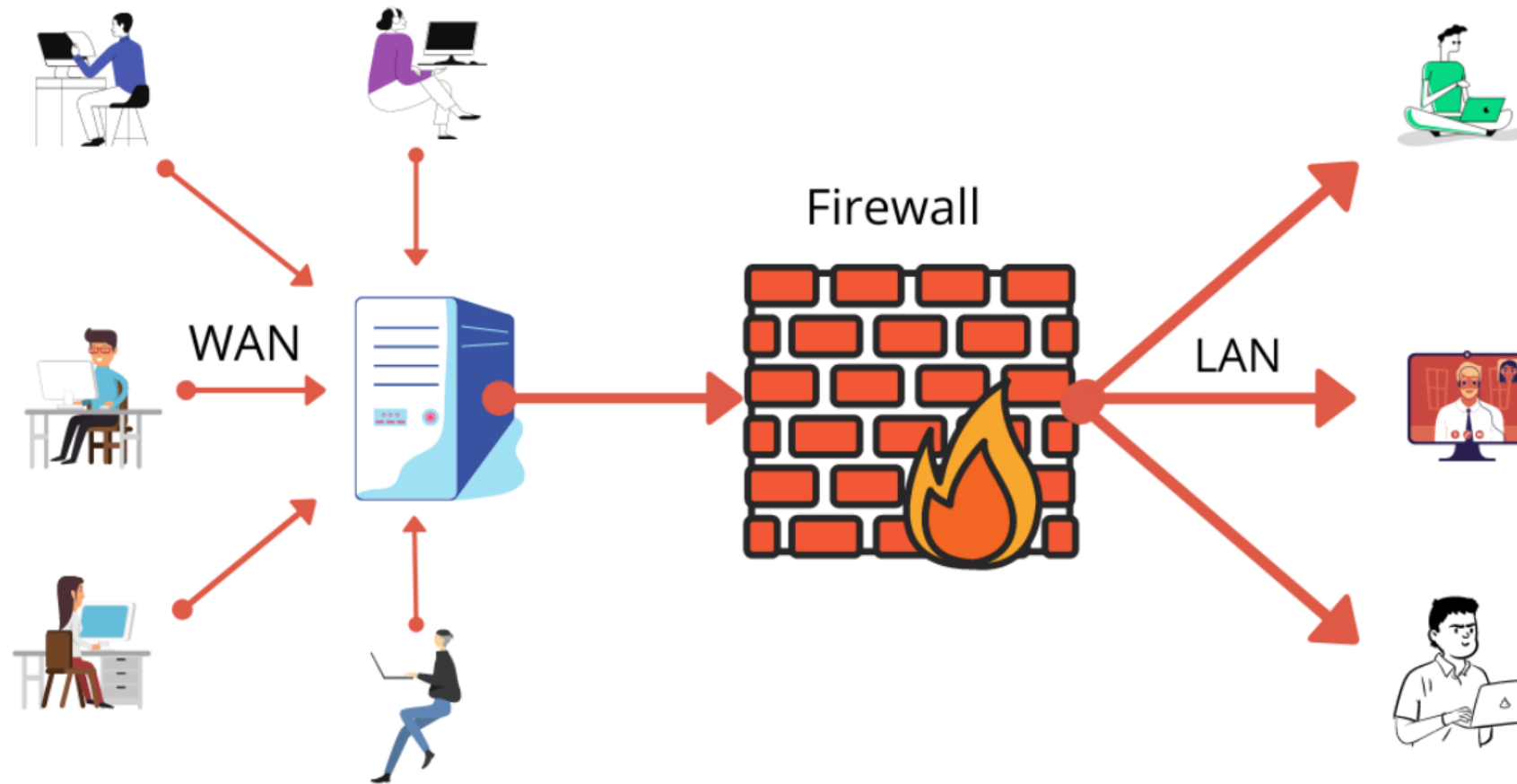
Firewall's (in)capabilities

- ✓ Provide a focal point for monitoring.
- ✓ Provide a central point for access control (who can do what).
- ✓ Limit the damage that a network security problem can do to the overall network.

Firewall's (in)capabilities

- ✓ Provide a focal point for monitoring.
- ✓ Provide a central point for access control (who can do what).
- ✓ Limit the damage that a network security problem can do to the overall network.
- ✓ Protect against malicious insiders.
- ✓ Protect a connection that doesn't go through it!!
- ✓ Protect against completely new threats.
- ✓ Protect against viruses, Trojans etc.

Firewall Deployment



Firewall Deployment

- All traffic from inside to outside, and vice versa, must pass through the firewall.

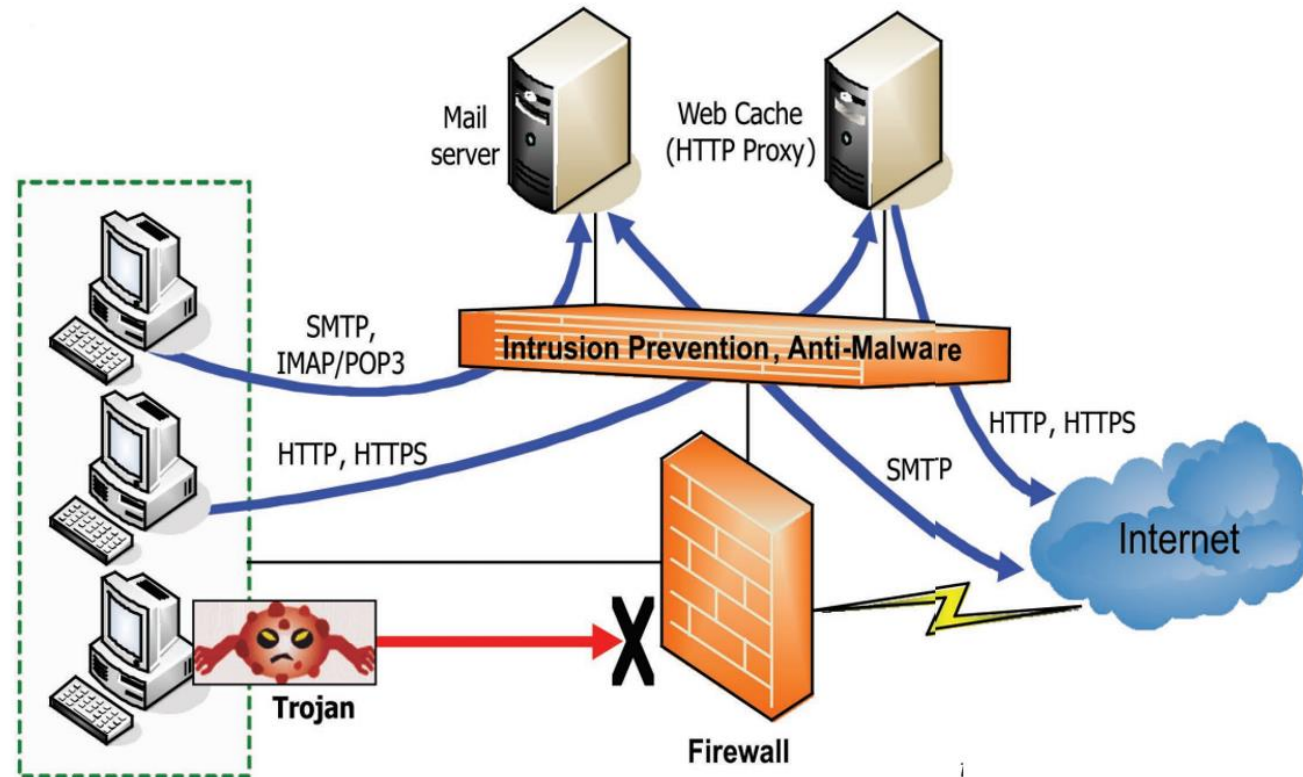
Firewall Deployment

- All traffic from inside to outside, and vice versa, must pass through the firewall.
- Only authorized traffic, as defined by the local security policy, will be allowed to pass

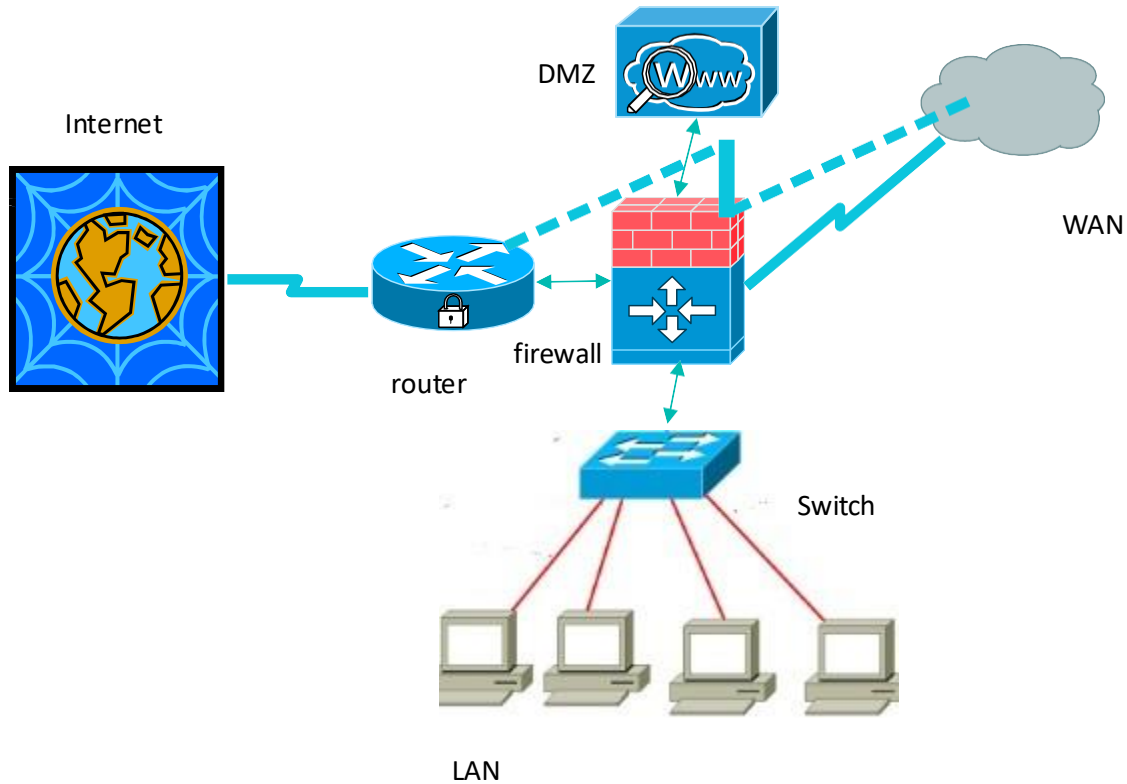
Firewall Deployment

- All traffic from inside to outside, and vice versa, must pass through the firewall.
- Only authorized traffic, as defined by the local security policy, will be allowed to pass
- Ideal Assumption: The firewall itself is immune to penetration.
 - E.g. Cisco iOS vulnerabilities, Juniper Junos vulnerabilities.

Typical Deployment



Our generic design



Generic Techniques for Enforcing policy

Generic Techniques for Enforcing policy

- **Service control:** Determines the types of Internet services that can be accessed.

Generic Techniques for Enforcing policy

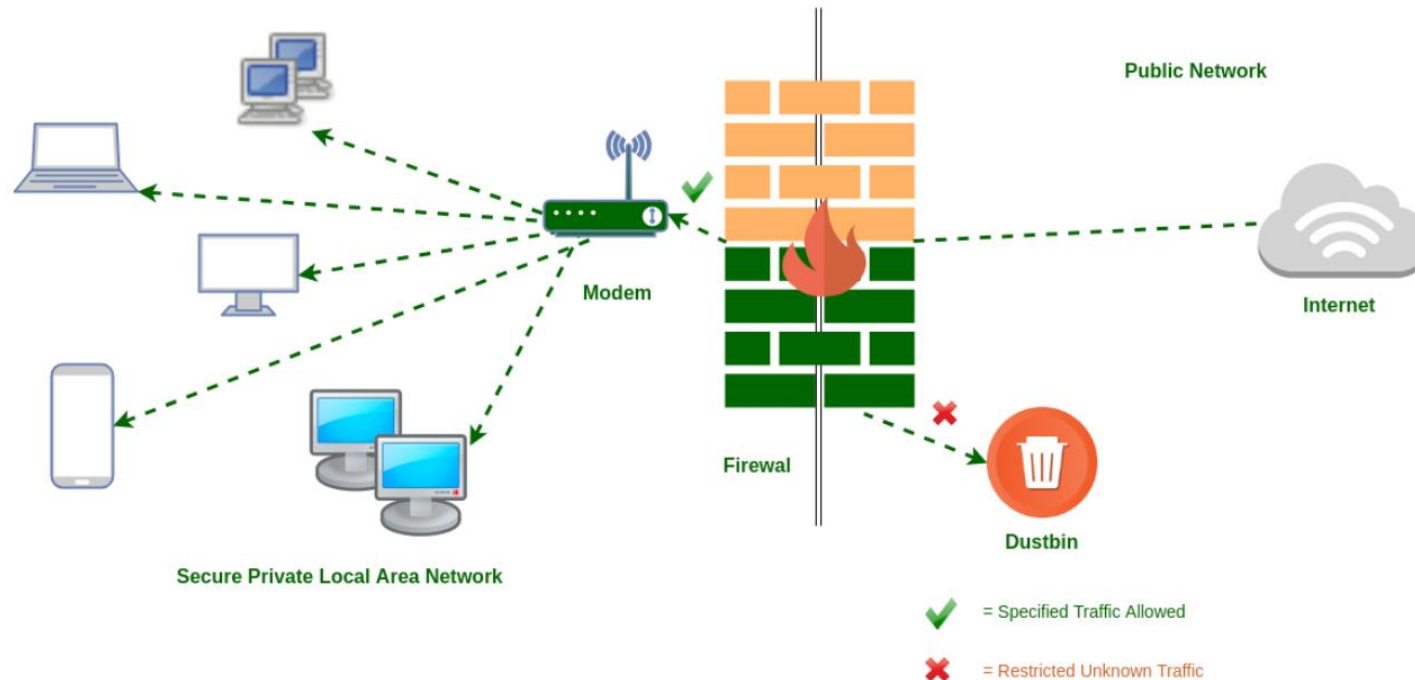
- **Service control:** Determines the types of Internet services that can be accessed.
- **Direction control:** Determines the direction in which particular service requests are allowed.

Generic Techniques for Enforcing policy

- **Service control:** Determines the types of Internet services that can be accessed.
- **Direction control:** Determines the direction in which particular service requests are allowed.
- **User control:** Controls access to a service according to which user is attempting to access it. IP based filtering or authentication with IPSec.

Types of firewalls

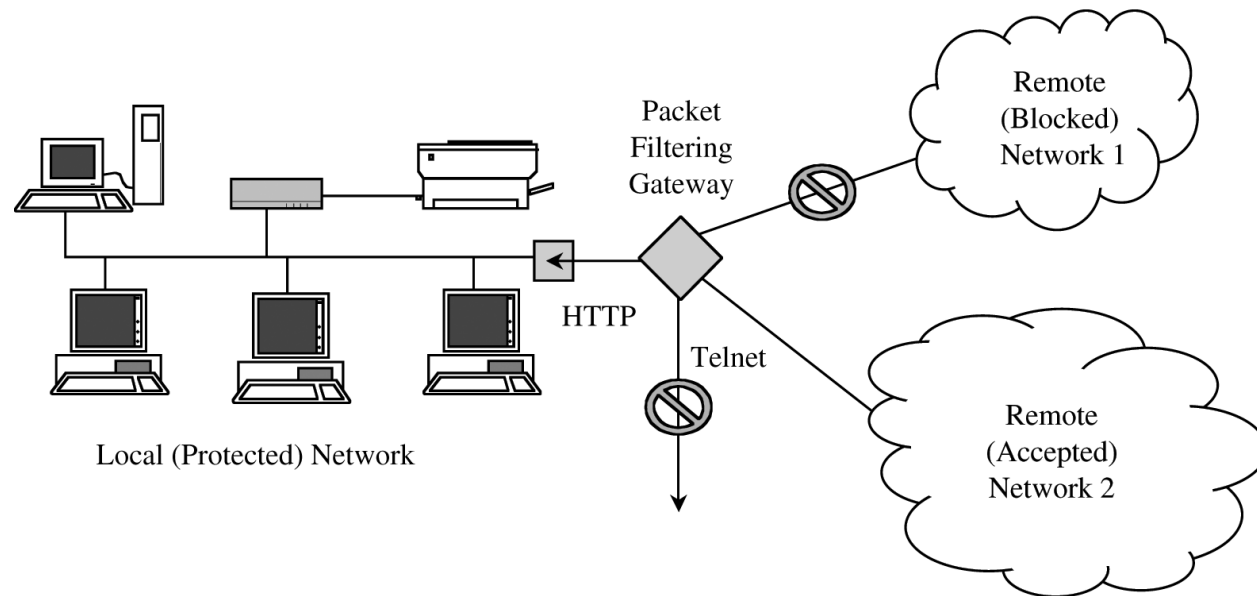
- Packet Filtering Firewall (works at the network layer, IP)
- Circuit-level gateway (works at the transport layer, TCP)
- Stateful Inspection Firewall
- Application Level Gateway (works at higher layers)



Types of Firewalls

- Firewalls have a wide range of capabilities. Types of firewalls include
 - packet filtering gateways or screening routers
 - stateful inspection firewalls
 - application proxies
 - guards
 - personal firewalls
- Each type does different things; no one is necessarily "right" and the others "wrong."
 - the important question to ask when choosing a type of firewall is what threats an installation needs to counter

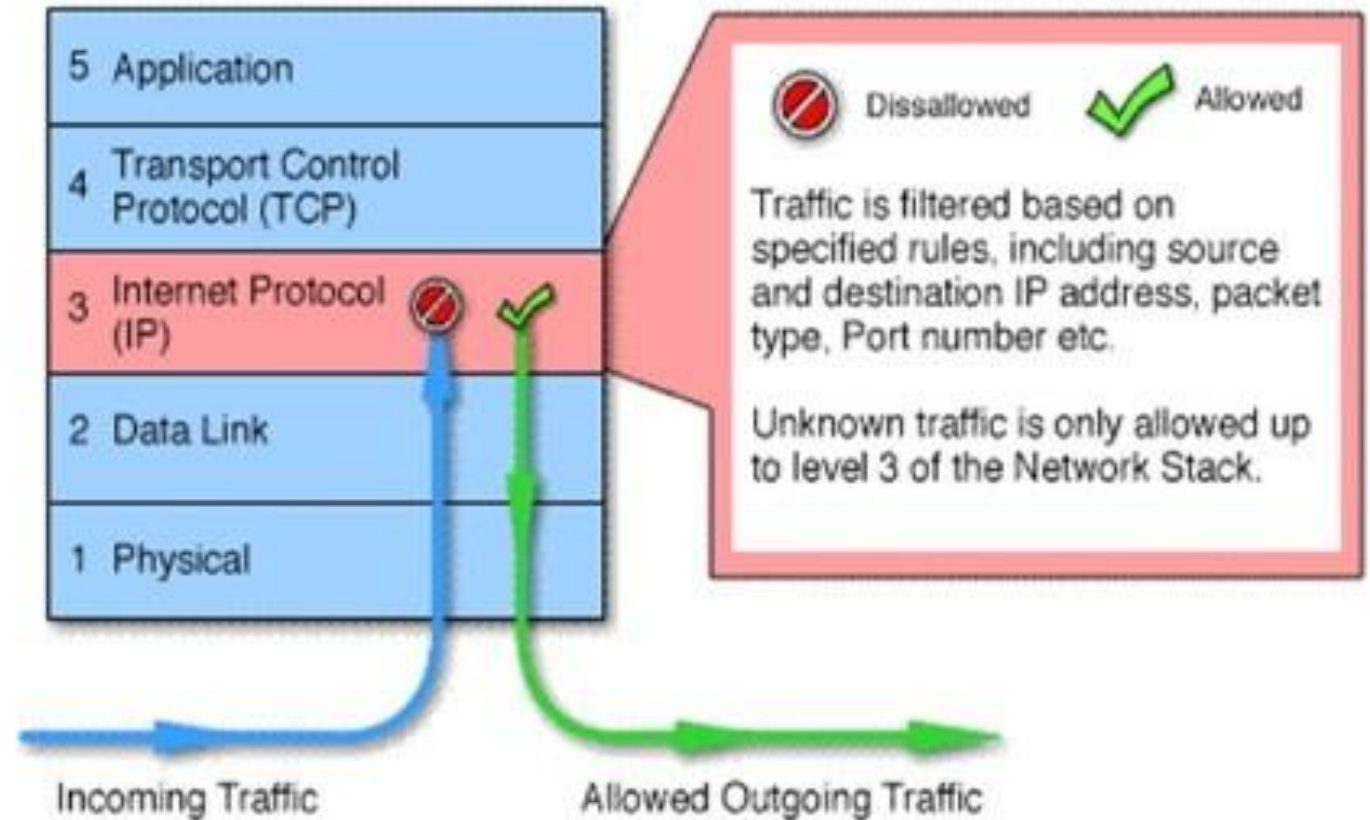
Packet Filtering Gateway



- the simplest, and in some situations, the most effective type of firewall
 - controls access to packets on
 - the basis of packet address (source or destination)
 - or specific transport protocol type (such as HTTP web traffic).

Packet filters

- Works at most up to transport layer, but at individual packet level.
- Stateless
- Fast processing



Example packet filters

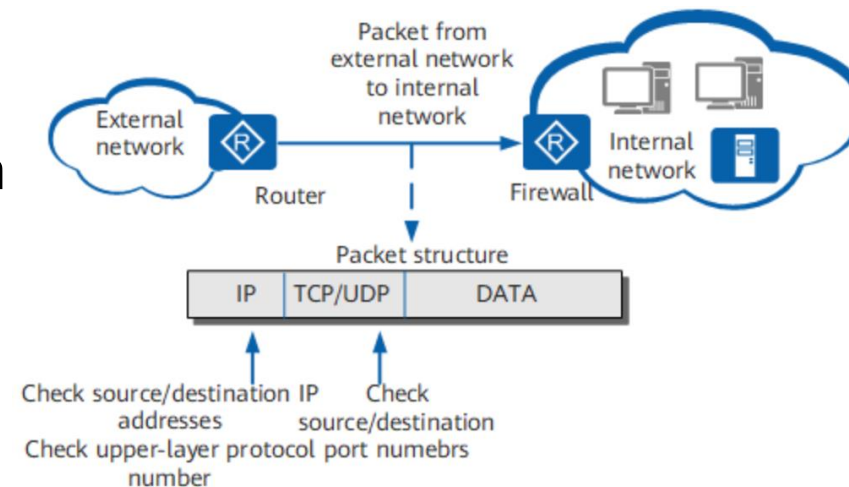
Rule No	Action	Src IP	Dst IP	Src Port	Dst Port	Direction	Description
1	Block	IP1	*	*	*	IN	Block packets from IP1
2	Pass	*	IP_SMTP	*	25	IN	Allow packets to mail gateway
3	Pass	*	*	*	*	OUT	Allow outgoing
4	Block	*	*	*	*	IN	Block Everything Else

Problems with Packet filters

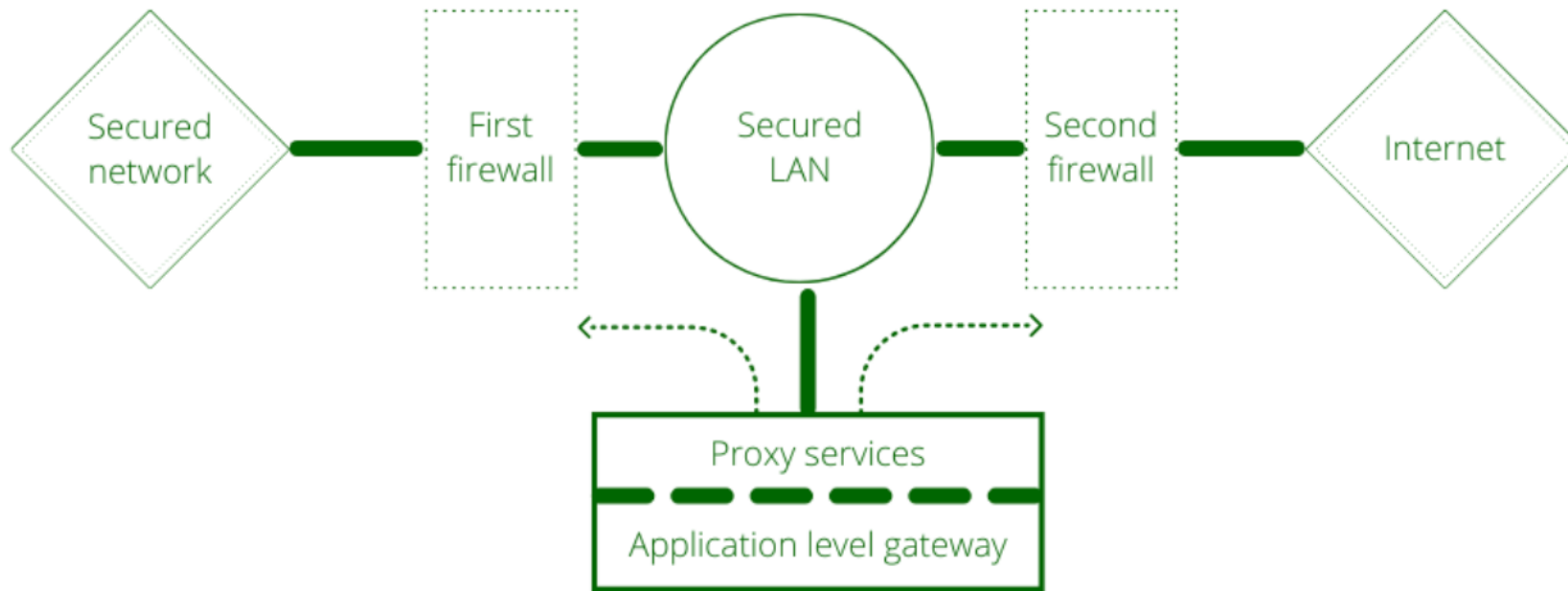
- Lack of upper-layer functionality;
- Do not support advanced user authentication schemes;
- Cannot block specific application commands: either the application is disallowed, or all its functions are permitted;

Pros:

- Simple;
- Transparent for users;
- Very fast.

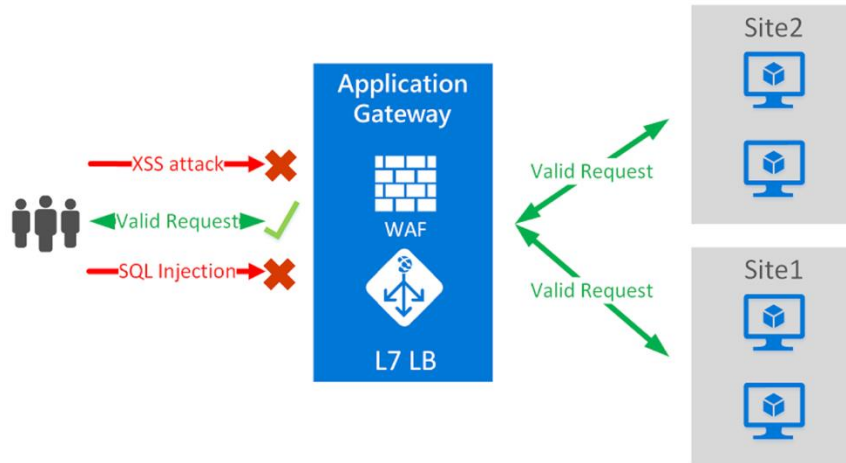


Application gateway (aka Proxy)



Application level gateway

Application gateway (aka Proxy)

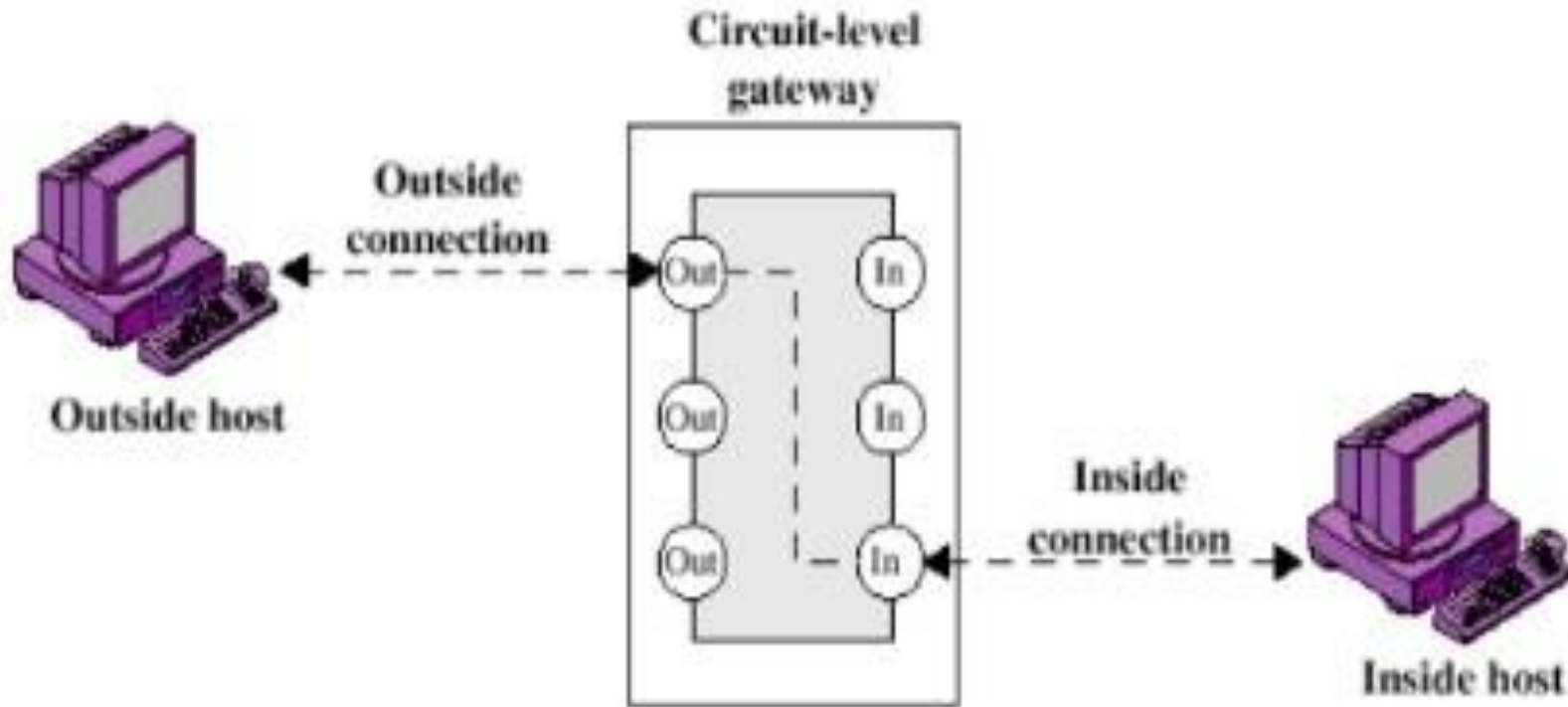


- Filters traffic at application layer
- Specific to applications which are configured.
- Works at client-server mode
- Offer High level of security
- Have impact on network performance

Application Proxy

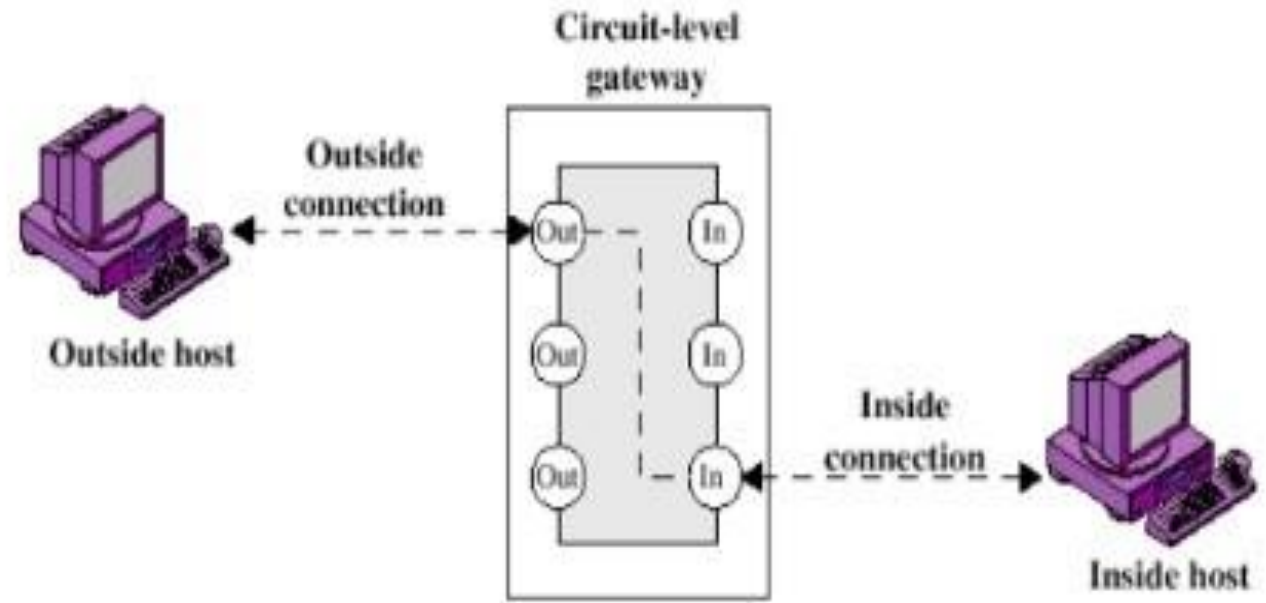
- simulates the (proper) effects of an application so that the application receives only requests to act properly.
 - An application proxy runs pseudo-applications
 - As an example of application proxying, consider the FTP (file transfer) protocol.
 - Specific protocol commands fetch (get) files from a remote location, store (put) files onto a remote host, list files (ls) in a directory on a remote host, and position the process (cd) at a particular point in a directory tree on a remote host.
 - Some administrators might want to permit gets but block puts, and to list only certain files or prohibit changing out of a particular directory
 - The proxy would simulate both sides of this protocol exchange
 - For example, the proxy might accept get commands, reject put commands, and filter the local response to a request to list files.

Circuit Level gateway



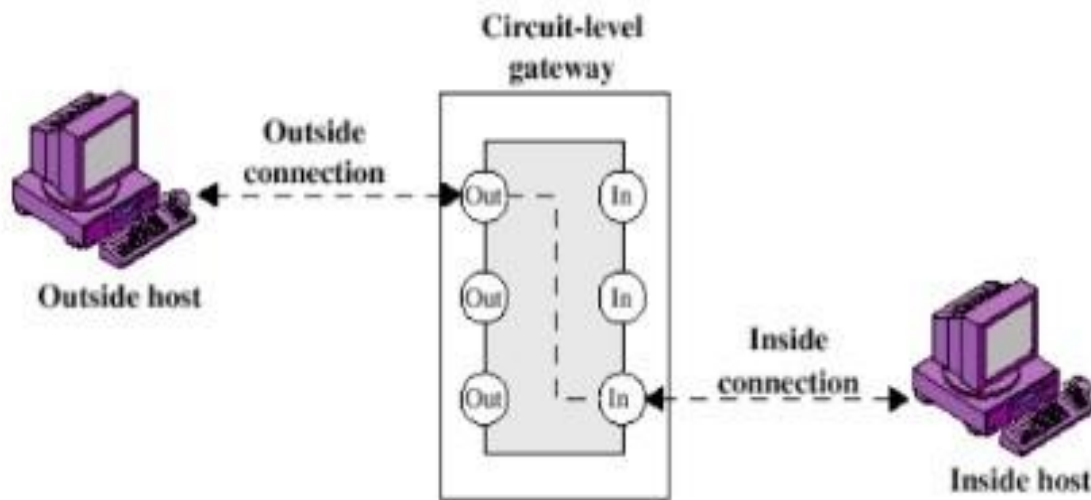
Circuit Level gateway

- Client-server mode.



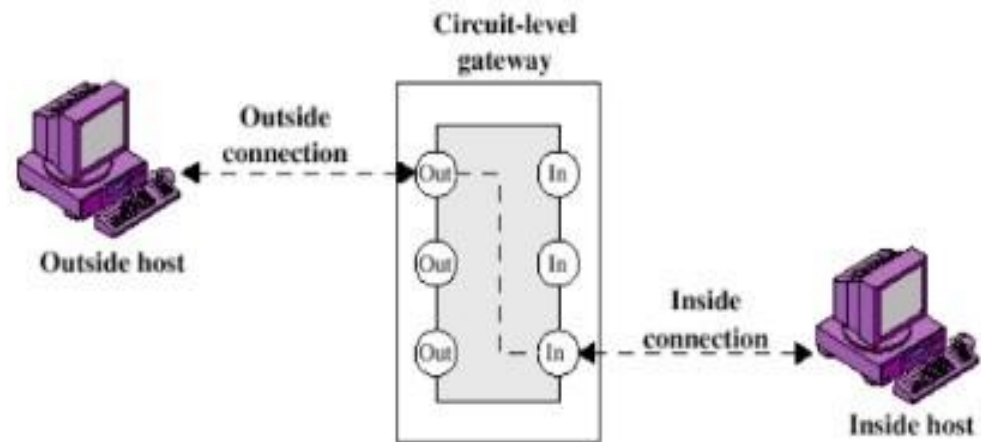
Circuit Level gateway

- Client-server mode.
- Always two connections (NAT/PAT).



Circuit Level gateway

- Client-server mode.
- Always two connections (NAT/PAT).
- Hides internal network!
- Uses SOCKS protocol for client server connection.



Stateful Inspection Firewall

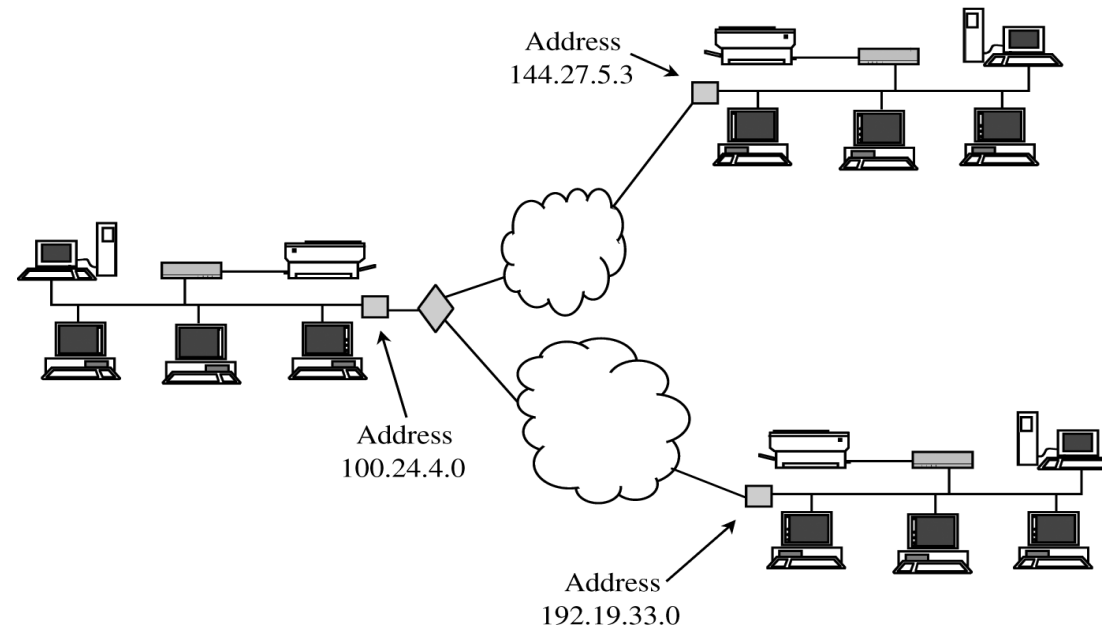
- Filtering firewalls work on packets one at a time, accepting or rejecting each packet and moving on to the next.
 - They have no concept of "state" or "context" from one packet to the next.
- A **stateful inspection firewall** maintains state information from one packet to another in the input stream.
- One classic approach used by attackers is to break an attack into multiple packets
 - forcing some packets to have very short lengths so that a firewall cannot detect the signature of an attack split across two or more packets

Stateful Inspection Firewall

- Remember that with the TCP protocols, packets can arrive in any order
 - the protocol suite is responsible for reassembling the packet stream in proper order before passing it along to the application
- A stateful inspection firewall would track the sequence of packets and conditions from one packet to another to thwart such an attack

Packet Filtering Gateway

- For example, suppose an international company has three LANs at three locations throughout the world, as shown in figure below.
 - The company might want communication only among the three LANs of the corporate network



Stateful Inspection Firewall

- Filtering firewalls work on packets one at a time, accepting or rejecting each packet and moving on to the next.
 - They have no concept of "state" or "context" from one packet to the next.
- A **stateful inspection firewall** maintains state information from one packet to another in the input stream.
- One classic approach used by attackers is to break an attack into multiple packets
 - forcing some packets to have very short lengths so that a firewall cannot detect the signature of an attack split across two or more packets

Stateful Inspection Firewall

- Remember that with the TCP protocols, packets can arrive in any order
 - the protocol suite is responsible for reassembling the packet stream in proper order before passing it along to the application
- A stateful inspection firewall would track the sequence of packets and conditions from one packet to another to thwart such an attack

Guard

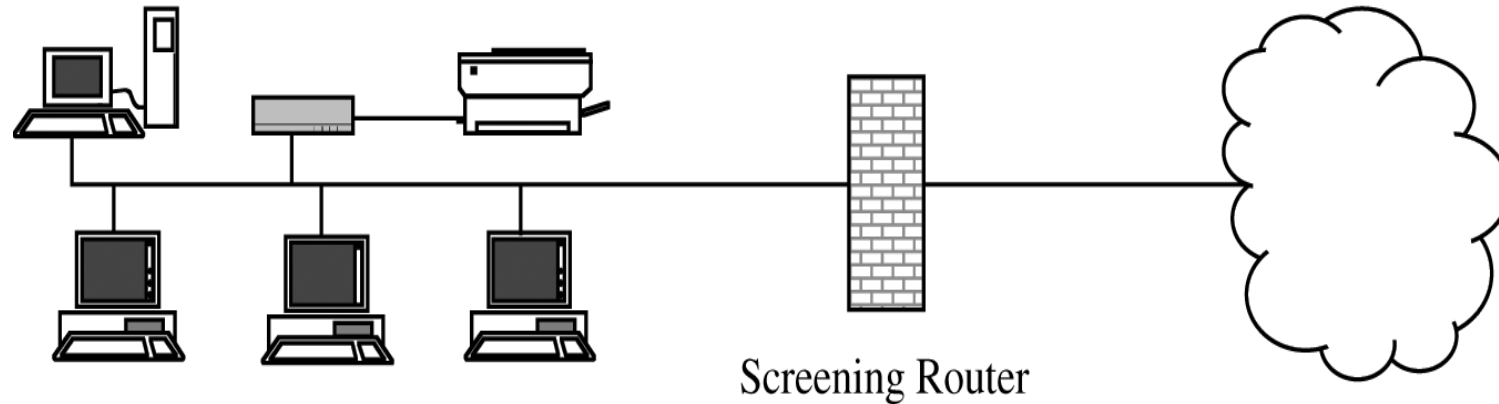
- A guard is a sophisticated firewall.
 - Like a proxy firewall, it receives protocol data units, interprets them, and passes through the same or different protocol data units that achieve either the same result or a modified result.
 - The guard decides what services to perform on the user's behalf in accordance with its available knowledge, such as
 - whatever it can reliably know of the (outside) user's identity
 - previous interactions,
 - and so forth.
 - The degree of control a guard can provide is limited only by what is computable.
 - Example
 - A university wants to allow its students to use e-mail up to a limit of so many messages or so many characters of e-mail in the last so many days.
 - guards and proxy firewalls are similar enough that the distinction between them is sometimes fuzzy.

Personal Firewalls

- A **personal firewall** is an application program that runs on a workstation to block unwanted traffic
 - can complement or compensate for the lack of a regular firewall
- Commercial implementations of personal firewalls include Norton Personal Firewall from Symantec, McAfee Personal Firewall, and Zone Alarm from Zone Labs (now owned by CheckPoint).
- The personal firewall is configured to enforce some policy.
 - computers on the company network, are highly trustworthy, but most other sites are not.
- Personal firewalls can also generate logs of accesses

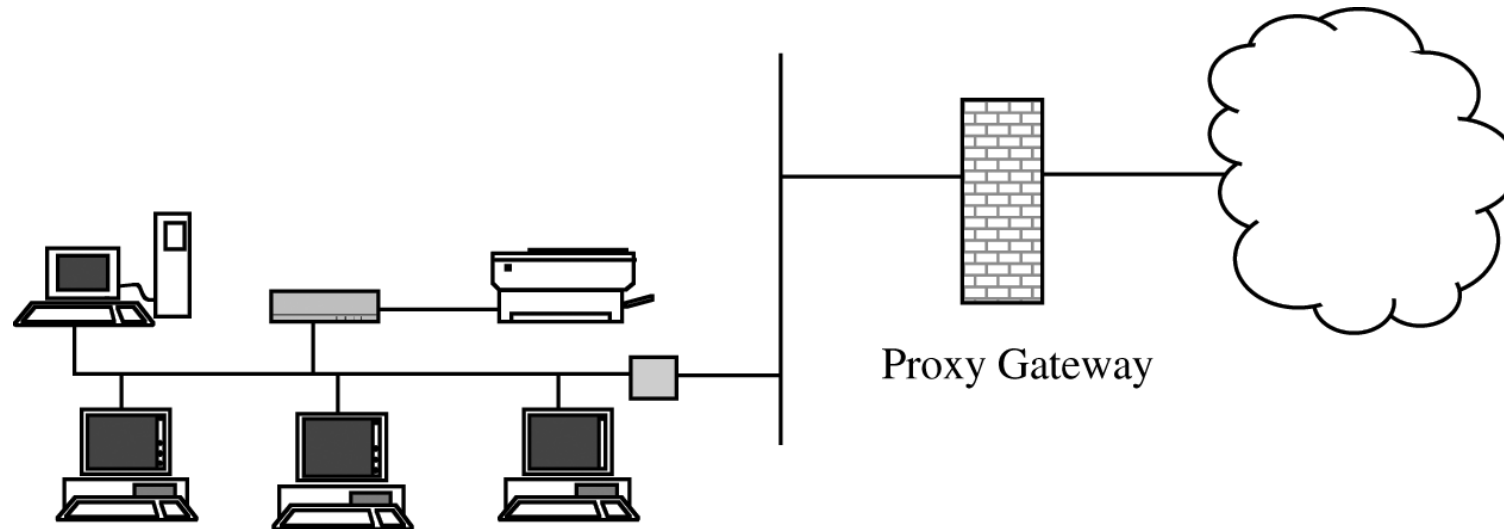
Example Firewall Configurations

- The simplest use of a firewall
 - screening router positioned between the internal LAN and the outside network connection
 - If the firewall router is successfully attacked, then all traffic on the LAN to which the firewall is connected is visible



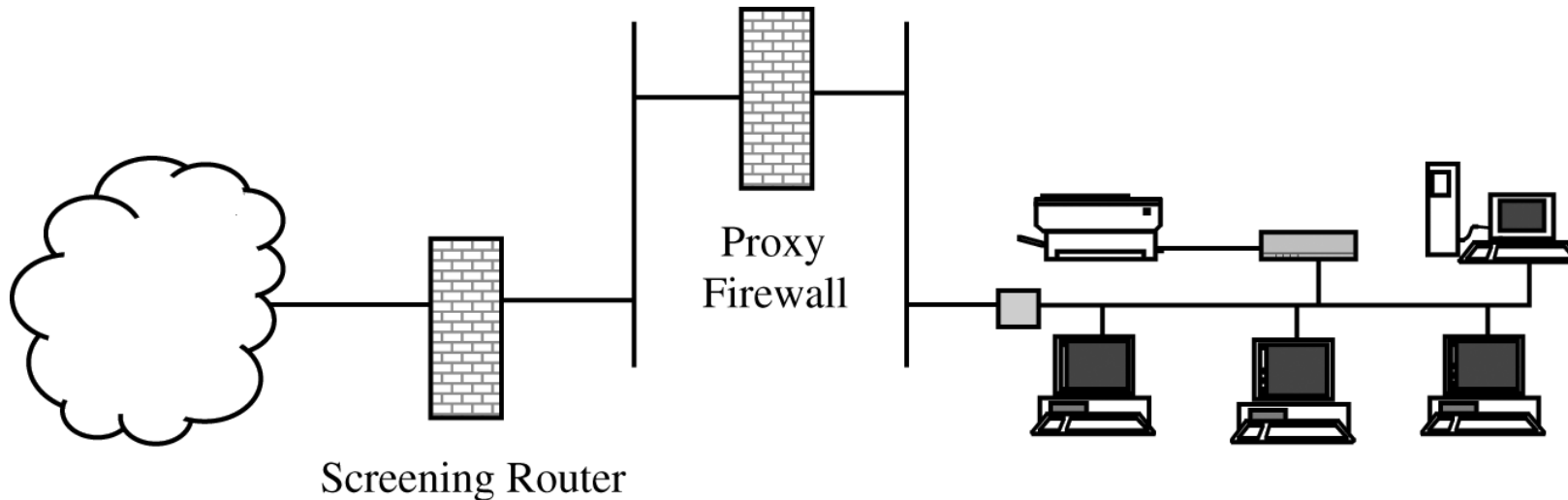
Example Firewall Configurations

- To reduce this exposure, a proxy firewall is often installed on its own LAN.
 - In this way the only traffic visible on that LAN is the traffic going into and out of the firewall



Example Firewall Configurations

- For even more protection, we can add a screening router to this configuration.
 - the screening router ensures address correctness to the proxy firewall; the proxy firewall filters traffic according to its proxy rules

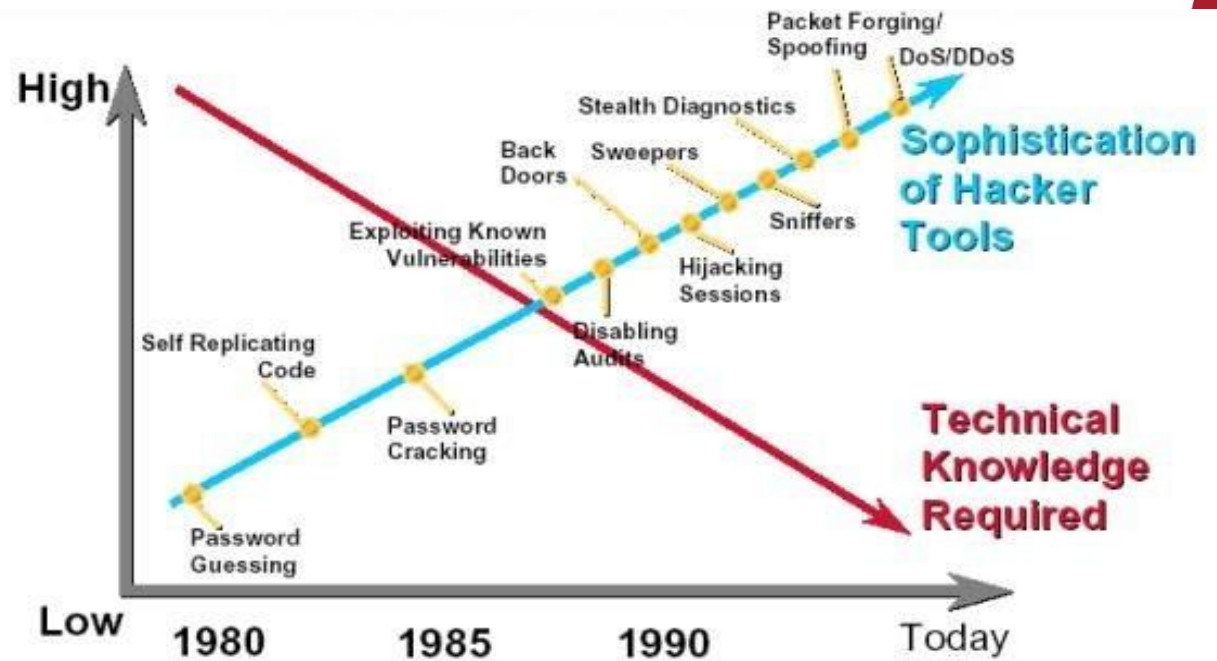


Intrusions

- DARPA IDS Evaluation Project 1998 attack categories¹:
 - Probes (e.g. port scanning, fingerprinting)
 - Denial of Service (DoS) (e.g. packet flooding, crash)
 - Remote to Local (R2L)
 - User to Root (U2R)

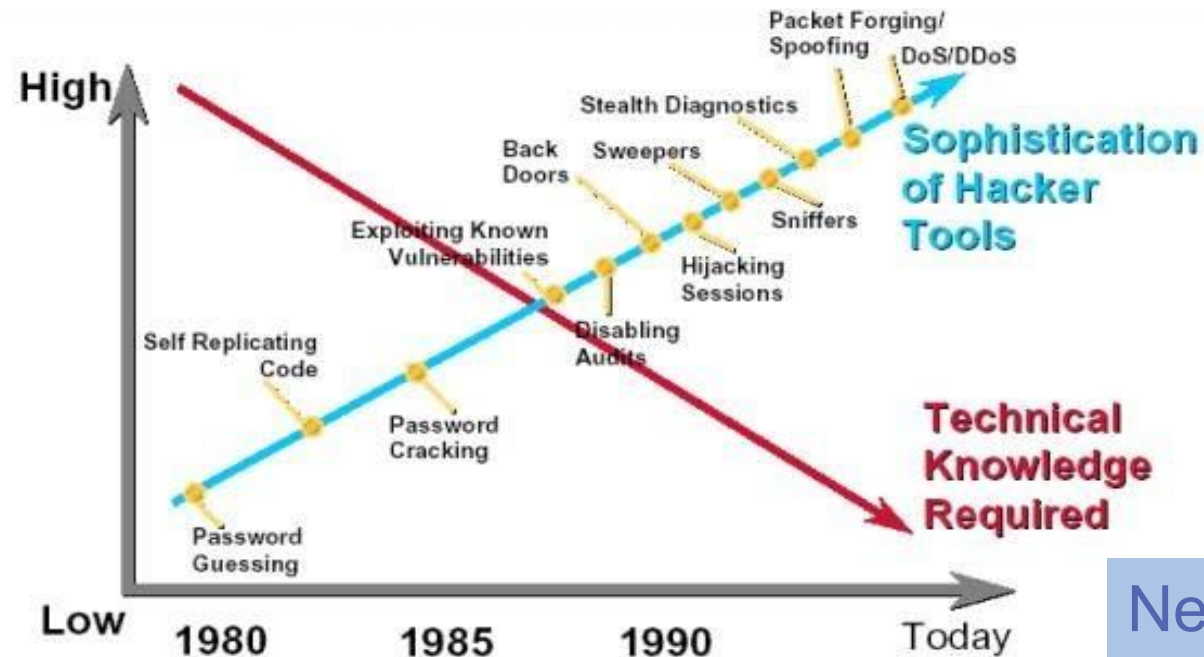
<http://www.ll.mit.edu/mission/communications/cyber/CSTcorpora/ideval/docs/attackDB.html>

Attacker's Picture



Curtsey: Internet source

Attacker's Picture

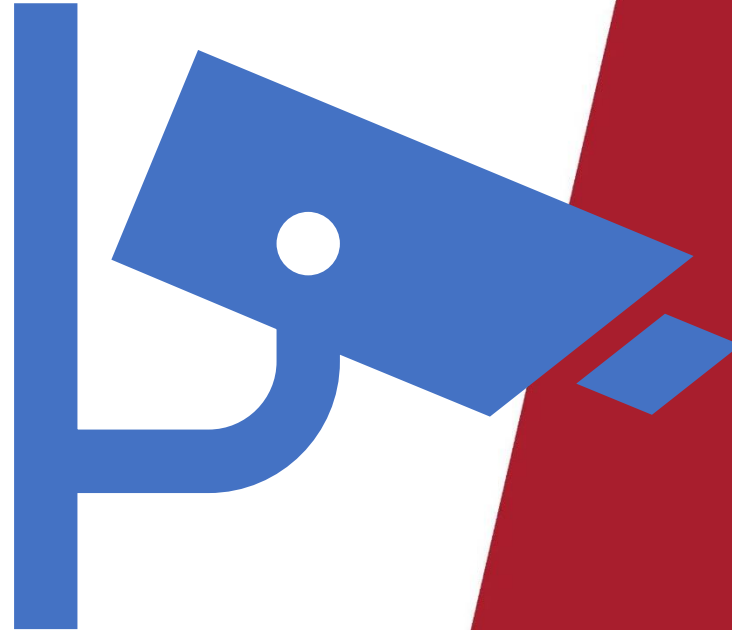


Curtsey: Internet source

Need of
automatic ways
to detect them!

Intrusion Detection Systems

- What is intrusion detection?

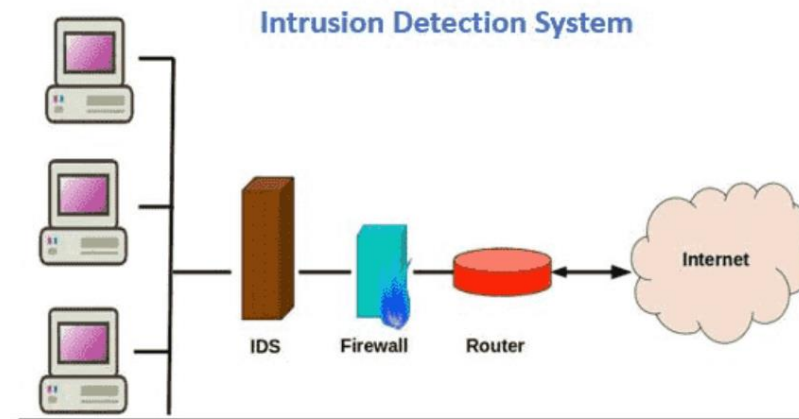


Intrusion Detection Systems (IDS)

- Many studies have shown that most computer security incidents are caused by insiders
 - people who would not be blocked by a firewall
 - The vast majority of harm from insiders is not malicious;
 - it is honest people making honest mistakes.
- Then, too, there are the potential malicious outsiders who have somehow passed the screens of firewalls and access controls.
- Prevention, although necessary, is not a complete computer security control;
 - detection during an incident copes with harm that cannot be prevented in advance

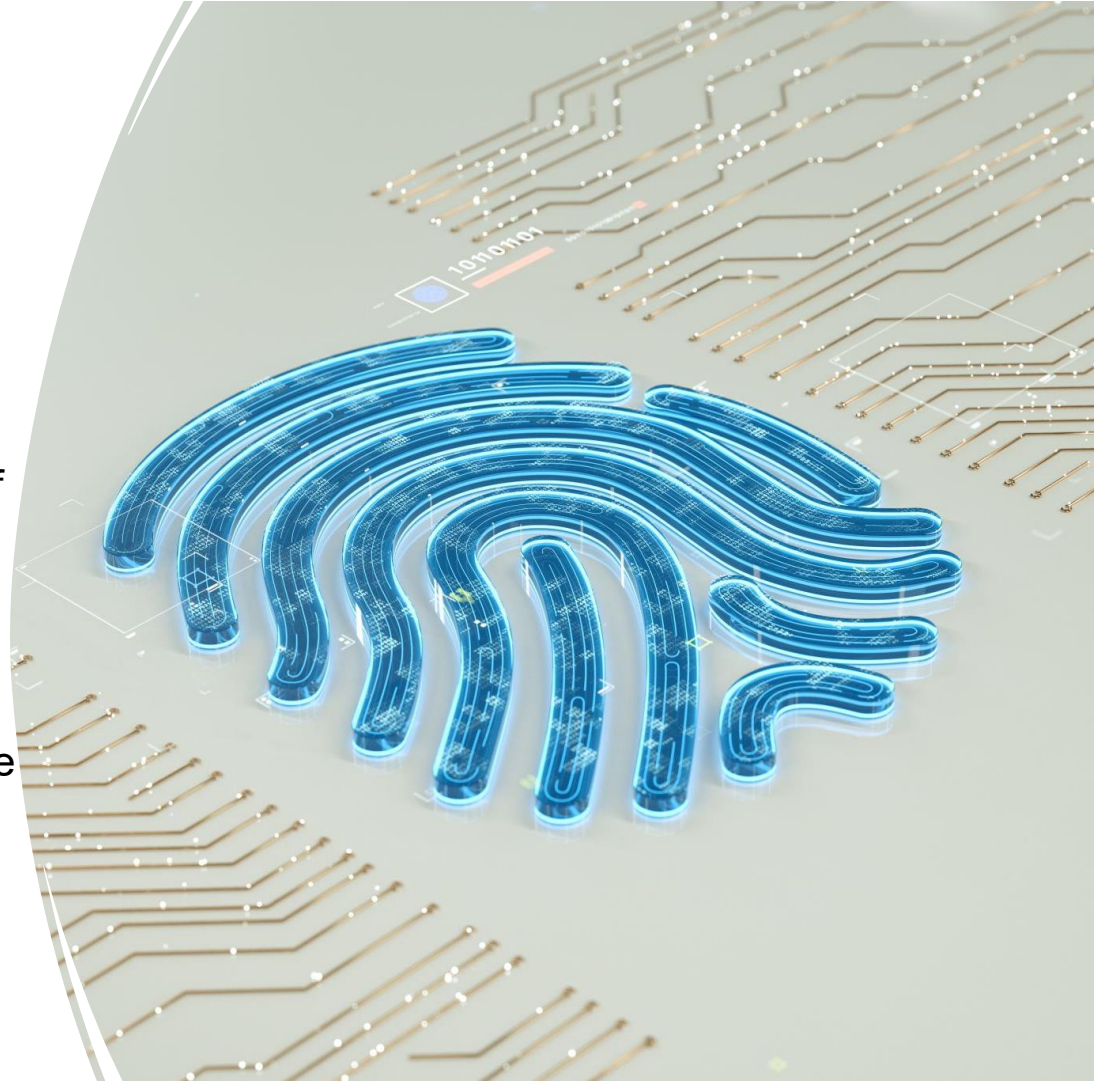
Intrusion Detection Systems (IDS)

- Intrusion detection systems complement these preventive controls as the next line of defense
- An **intrusion detection system (IDS)** is a device, typically another separate computer, that monitors activity to identify malicious or suspicious events.
 - An IDS is a sensor, like a smoke detector, that raises an alarm if specific things occur.



What is intrusion detection?

- Intrusion detection is the process of monitoring the events occurring in a computer system or network and analyzing them for signs of *intrusions*, defined as attempts to compromise the confidentiality, integrity, availability, or to bypass the security mechanisms of a computer or network.



Intrusion Detection Systems (IDS)

- IDSs perform a variety of functions:
 - monitoring users and system activity
 - auditing system configuration for vulnerabilities and misconfigurations
 - assessing the integrity of critical system and data files
 - recognizing known attack patterns in system activity
 - identifying abnormal activity through statistical analysis
 - managing audit trails and highlighting user violation of policy or normal activity
 - correcting system configuration errors
 - installing and operating traps to record information about intruders
- No one IDS performs all of these functions. Let us look more closely at the kinds of IDSs and their use in providing security.

Some (intended) General characteristics

Some (intended) General characteristics

- The ability to react in a timely fashion to prevent substantive damage
 - by automatic or manual intervention.
- The ability to identify which is the precursor of more serious
- attacks.
- The ability to identify a perpetrator.
- The ability to discover new attack patterns.
- The ability to produce evidence.

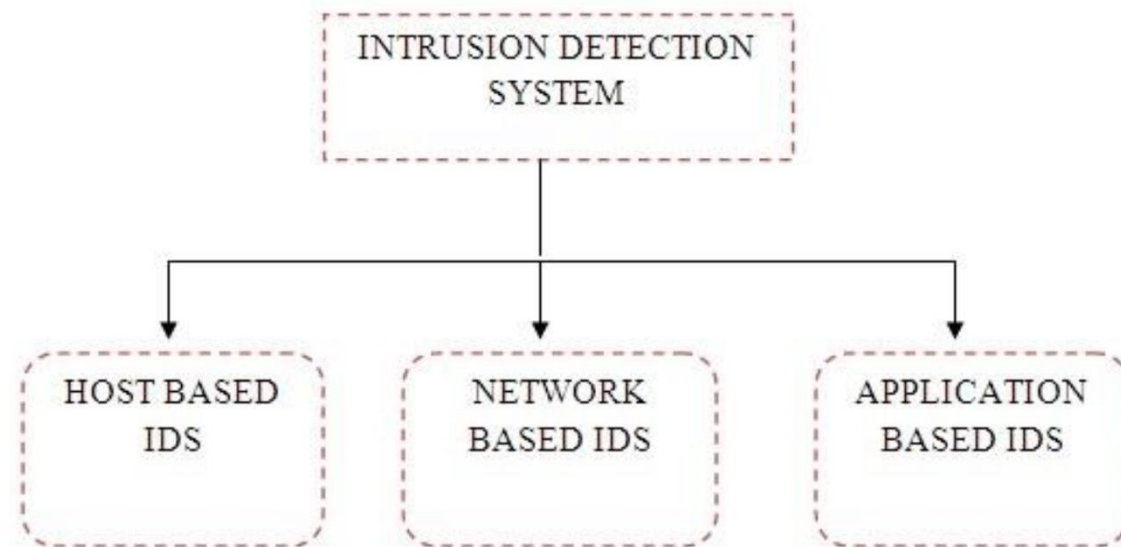
The SolarWinds Supply Chain Attack (2019-2020)

- State-sponsored hackers infiltrated SolarWinds and injected malicious code called SUNBURST into software updates for their Orion IT management platform, which was then distributed to approximately 18,000 customers including government agencies and Fortune 500 companies
- **It was digitally signed and trusted** The malicious updates were digitally signed by SolarWinds itself between March and May 2020, making them appear completely legitimate to security systems
- **It mimicked legitimate traffic**



Type of IDS

Type of IDS



Types of IDSs

- The two general types of intrusion detection systems are signature based and heuristic
 - **Signature-based** intrusion detection systems perform simple pattern-matching and report situations that match a pattern corresponding to a known attack type
 - **Heuristic** intrusion detection systems, also known as **anomaly-based**, build a model of acceptable behavior and flag exceptions to that model
- Intrusion detection devices can be **network-based** or **host-based**.
 - A **network-based** IDS is a stand-alone device attached to the network to monitor traffic throughout that network
 - a **host-based** IDS runs on a single workstation or client or host, to protect that one host.

Signature-Based Intrusion Detection

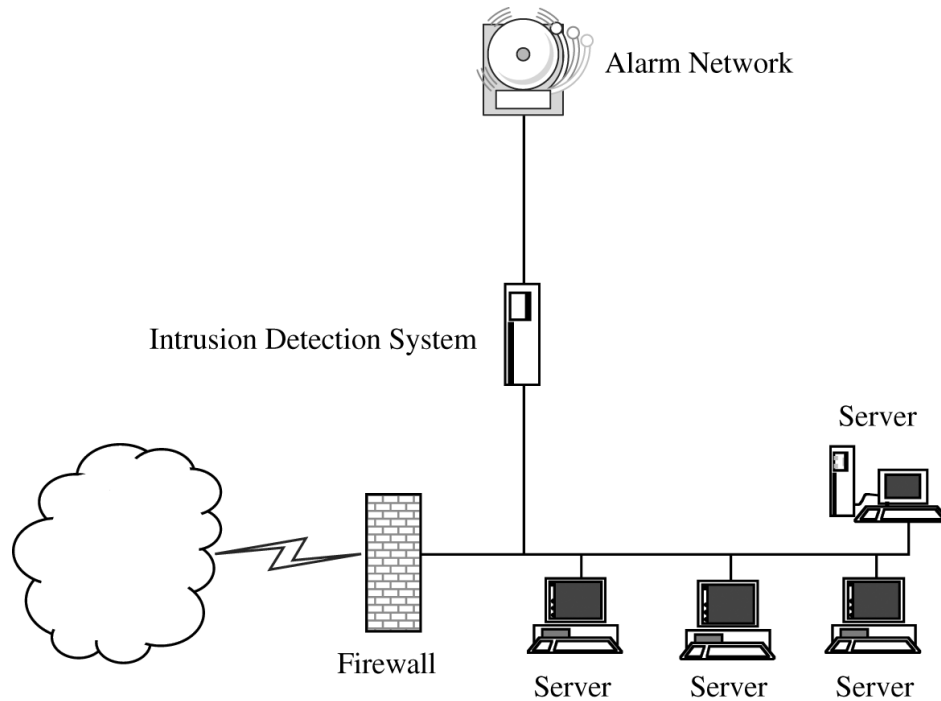
- Signature for a known attack types
 - series of TCP SYN packets sent to many different ports in succession and at times close to one another, as would be the case for a port scan.
 - Of course, signature-based IDSs cannot detect a new attack for which a signature is not yet installed in the database
 - And, an attacker will try to modify a basic attack in such a way that it will not match the known signature of that attack
- Signature-based intrusion detection systems tend to use **statistical analysis**.
 - To obtain sample measurements of key indicators (such as amount of external activity, number of active processes, number of transactions)
 - to determine whether the collected measurements fit the predetermined attack signatures.

Heuristic Intrusion Detection

- Instead of looking for matches, heuristic intrusion detection looks for behavior that is out of the ordinary.
- The original work in this area focused on the individual, trying to find characteristics of that person that might be helpful in understanding normal and abnormal behavior.
 - For example, one user might always start the day by reading e-mail, write many documents using a word processor, and occasionally back up files.
 - This user does not seem to use many administrator utilities.
 - If that person tried to access sensitive system management utilities, this new behavior might be a clue that someone else was acting under the user's identity.

Stealth Mode

- An IDS has two network interfaces: one for the network (or network segment) being monitored and the other to generate alerts and perhaps other administrative needs.



Goals for Intrusion Detection Systems

- Ideally, an IDS should be fast, simple, and accurate, while at the same time being complete.
 - It should detect all attacks with little performance penalty.
- An IDS could use some (or all) of the following design approaches:
 - Filter on packet headers
 - Filter on packet content
 - Maintain connection state
 - Use complex, multipacket signatures
 - Use minimal number of signatures with maximum effect
 - Filter in real time, online
 - Hide its presence
 - Use optimal sliding time window size to match signatures

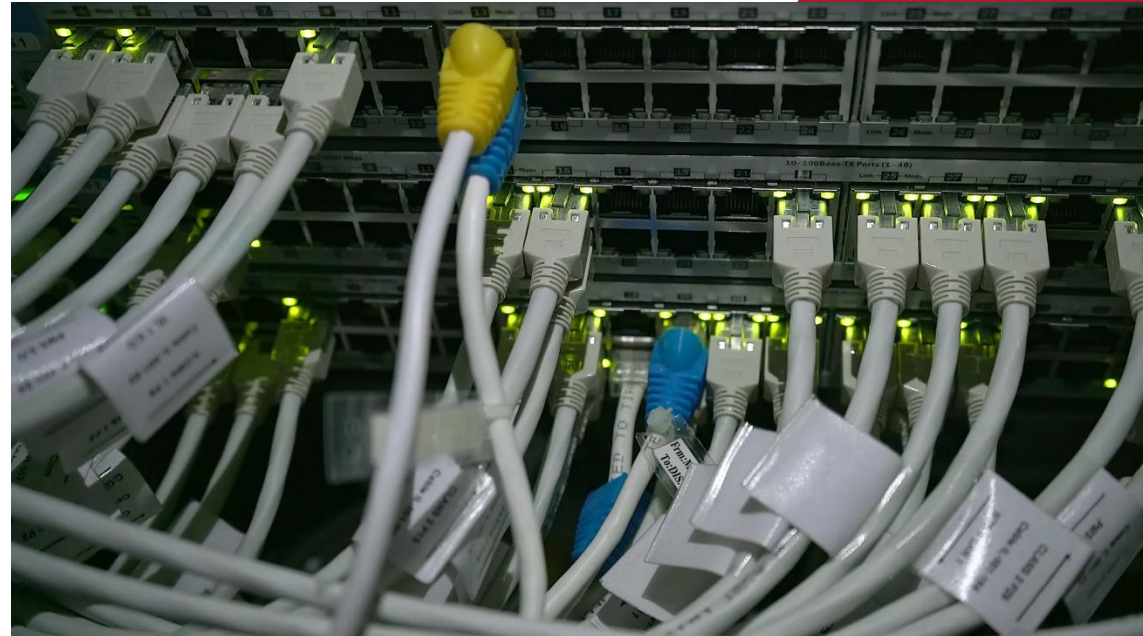
Responding to Alarms

- Whatever the type, an intrusion detection system raises an alarm when it finds a match.
- What are possible responses?
 - The range is unlimited and can be anything the administrator can imagine
- In general, responses fall into three major categories (any or all of which can be used in a single response):
 - Monitor, collect data, perhaps increase amount of data collected
 - watch the intruder, to see what resources are being accessed or what attempted attacks are tried
 - record all traffic from a given source for future analysis
 - Protect, act to reduce exposure
 - increasing access controls and even making a resource unavailable (for example, shutting off a network connection or making a file unavailable).
 - may be very visible to the attacker
 - Call a human

False Results

- Intrusion detection systems are not perfect, and mistakes are their biggest problem
 - raising an alarm for something that is not really an attack (called a **false positive**, or type I error in the statistical community)
 - Too many false positives means the administrator will be less confident of the IDS's warnings, perhaps leading to a real alarm's being ignored.
 - or not raising an alarm for a real attack (a **false negative**, or type II error).
 - mean that real attacks are passing the IDS without action.
- We say that the degree of false positives and false negatives represents the sensitivity of the system.
 - Most IDS implementations allow the administrator to tune the system's sensitivity, to strike an acceptable balance between false positives and negatives.

Network based IDS (NIDS)



Network based IDS (NIDS)

- NIDS uses a passive interface to capture network packets for analyzing.
- NIDS sensors placed around the globe can be configured to report back to a central site, enabling a small team of security experts to support a large enterprise.



Network based IDS (NIDS)

- NIDS uses a passive interface to capture network packets for analyzing.
- NIDS sensors placed around the globe can be configured to report back to a central site, enabling a small team of security experts to support a large enterprise.
- Most network-based IDSs are OS-Independent (in the sense that they can protect systems, running on different OSs).



Network based IDS (NIDS)

- NIDS uses a passive interface to capture network packets for analyzing.
- NIDS sensors placed around the globe can be configured to report back to a central site, enabling a small team of security experts to support a large enterprise.
- Most network-based IDSs are OS-Independent (in the sense that they can protect systems, running on different OSs.
- Provide better security against DOS attacks

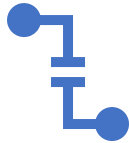


NIDS disadvantages

NIDS disadvantages



Cannot scan protocols or content if network traffic is encrypted



Intrusion detection becomes more difficult on modern switched networks (difficult to get all the packets to monitor, but getting better!)



Current network-based monitoring approaches may not efficiently handle high-speed networks.



Most of Network-based systems are based on predefined attack signatures--signatures that will always be a step behind the latest underground exploits (zero-days)

Host based IDS (HIDS)

- HIDS runs on the system, it is protecting.
- It has better information about the health of the system- more sources of information.
- HIDS are better at detecting more sophisticated attacks.
- OS dependent.
- *For HIDS, reverse the points for advantage/disadvantages of NIDS*
- *Example: Anti-virus software*

Measuring the effectiveness

- Obviously, not every attack can be detected by an IDS and not every alert by an IDS is an attack!

Actual	Reported	Attack	Not-attack
Attack		True positive (TP)	False negative (FN)
Not- attack (benign)		False positive (FP)	True negative (TN)

Measuring the effectiveness

- Obviously, not every attack can be detected by an IDS and not every alert by an IDS is an attack!

Actual ↓ Reported →	Attack	Not-attack
Attack	True positive (TP)	False negative (FN)
Not- attack (benign)	False positive (FP)	True negative (TN)

$$DR = \frac{TP}{TP + FN}$$

DR: detection rate (*aka Recall*).

Precision: What proportion of positive identifications was actually correct?

$$Precision = \frac{TP}{TP + FP}$$

Measuring the effectiveness

- Obviously, not every attack can be detected by an IDS and not every alert by an IDS is an attack!

Actual ↓ Reported →	Attack	Not-attack
Attack	True positive (TP)	False negative (FN)
Not- attack (benign)	False positive (FP)	True negative (TN)

$$DR = \frac{TP}{TP + FN}$$

DR: detection rate (*aka Recall*).

Precision: What proportion of positive identifications was actually correct?

$$Precision = \frac{TP}{TP + FP}$$

Ideally, one would like to have 0 FP and 0 FN

Types of IDS

- Based on Processing
 - Misuse detection (a.k.a. signature/rule based IDS) :
 - analyzes system activity, looking for events or sets of events that match a predefined pattern of events that describe a known attack
 - Very effective in detecting known attacks
 - Not good at detection new attacks.

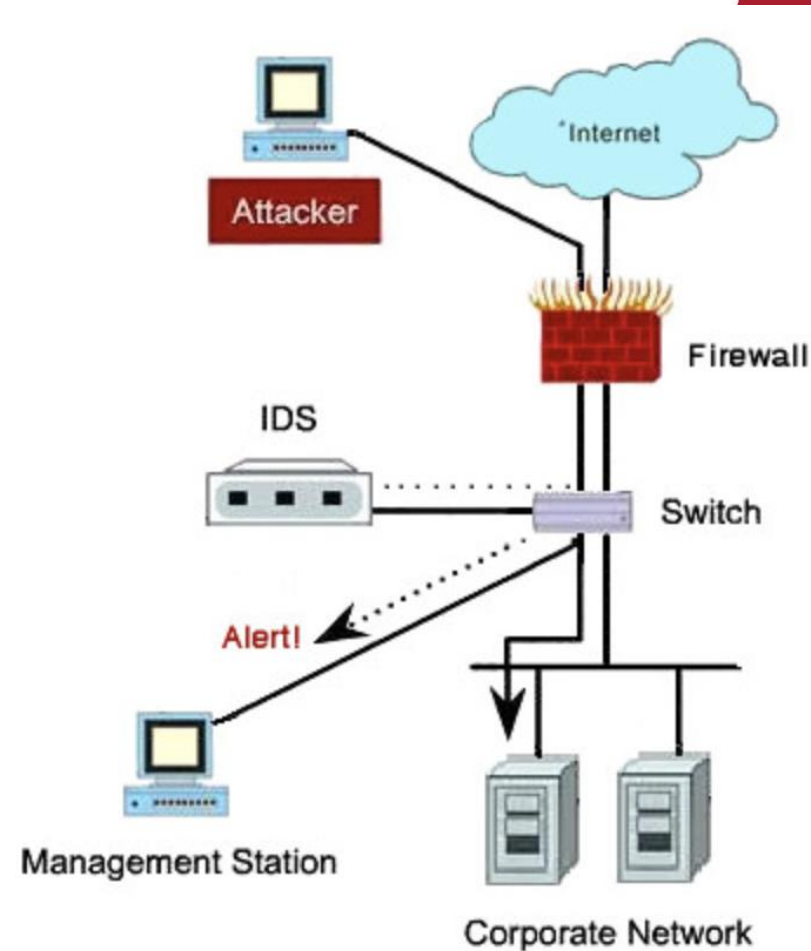
Types of IDS

- Based on Processing
 - Misuse detection (a.k.a. signature/rule based IDS) :
 - analyzes system activity, looking for events or sets of events that match a predefined pattern of events that describe a known attack
 - Very effective in detecting known attacks
 - Not good at detection new attacks
 - Anomaly Detection:
 - Identifies abnormal unusual behavior (anomalies) on a host or network
 - Good at detecting new attacks
 - High rate of false positive
 - Often use statistical properties to learn profile

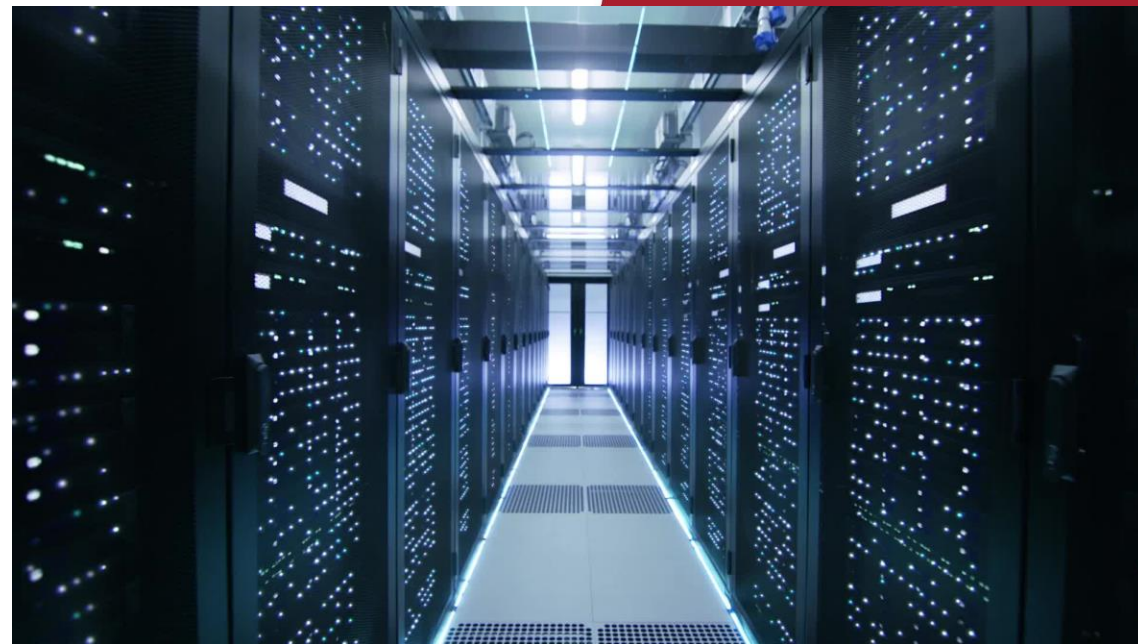
Current Trend in IDS

- Future research trends seem to be converging towards a model that is hybrid of the anomaly and misuse detection models.
- It is slowly acknowledged that neither of the models can detect all intrusion attempts on their own.

Deploying NIDS

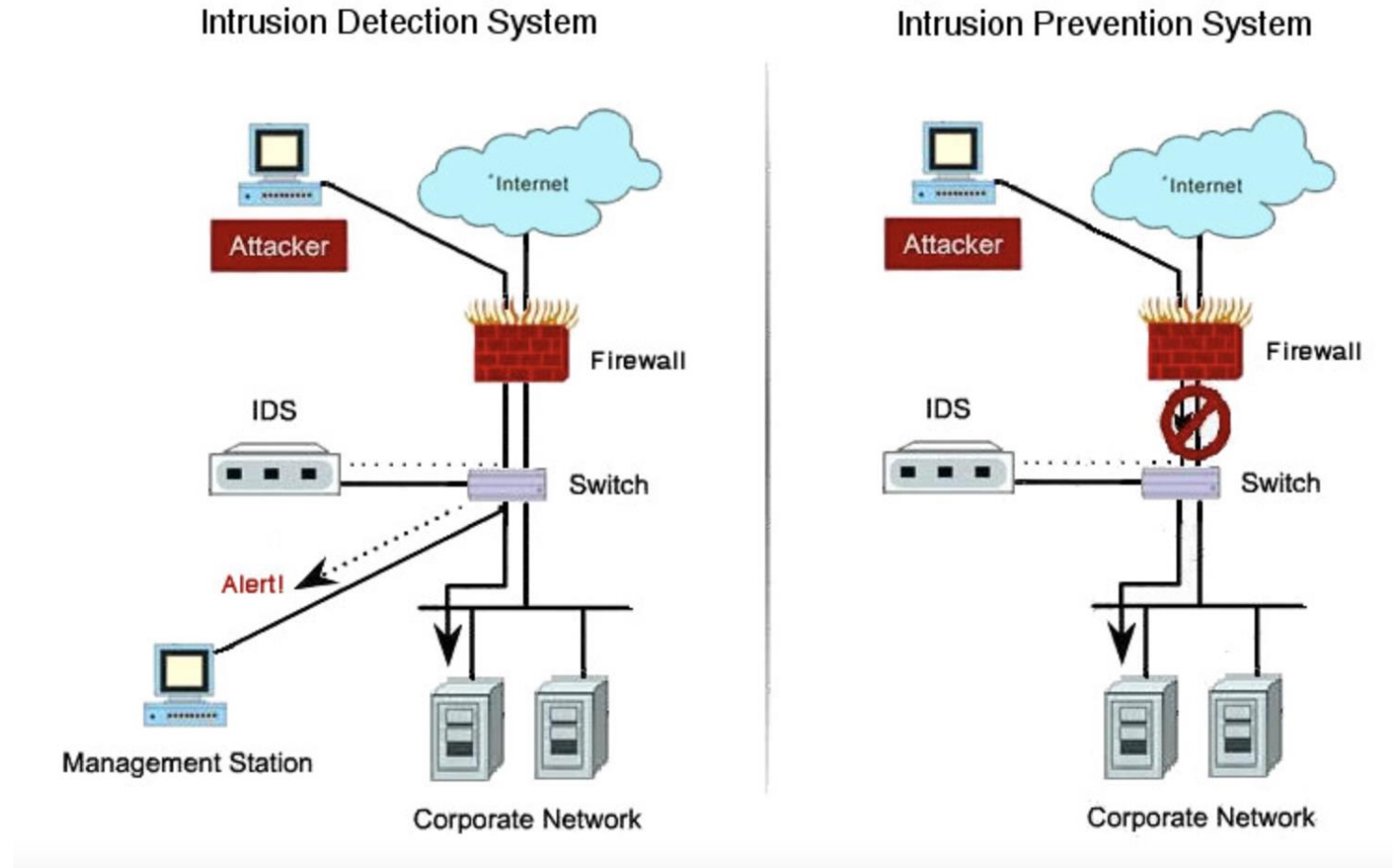


Intrusion Prevention System



Intrusion Prevention System

- $IPS = IDS + Firewall$



Intrusion Prevention System

IPS = IDS +
FIREWALL



AN IPS OFFERS THE ABILITY TO IDENTIFY AN INTRUSION, RELEVANCE, IMPACT AND PROPER ANALYSIS OF AN EVENT, AND THEN PASS THE APPROPRIATE INFORMATION AND COMMANDS TO THE FIREWALLS, SWITCHES AND OTHER NETWORK DEVICES TO MITIGATE THE EVENT'S RISK.

Intrusion Prevention System

IPS = IDS + Firewall

An IPS offers the ability to identify an intrusion, relevance, impact and proper analysis of an event, and then pass the appropriate information and commands to the firewalls, switches and other network devices to mitigate the event's risk.

An IPS is the next security layer to be introduced in the system that combines the protection of firewalls with the monitoring ability of an IDS to protect our networks with the analysis necessary to make the proper decisions on the fly.



Network
security!



Firewalls



IDS/IPS

